

Política Integrada de Seguridad de la Información

Controles A.5.2 · A.5.25 · A.5.35 · A.5.36 · A.6.3

ISO/IEC 27001:2022 — Evidencia Documental

Código:	POL-SGSI-001
Versión:	2.1
Fecha de emisión:	15 de enero de 2025
Fecha de revisión:	15 de enero de 2026
Propietario:	Oficial de Seguridad de la Información (CISO)
Aprobado por:	Comité de Seguridad de la Información

1. Introducción y alcance

La presente política establece los principios, responsabilidades y controles que Empresa Demo S.A. aplica para proteger la confidencialidad, integridad y disponibilidad de su información. Cubre los controles A.5.2, A.5.25, A.5.35, A.5.36 y A.6.3 del Anexo A de la norma ISO/IEC 27001:2022 y es de cumplimiento obligatorio para todo el personal, contratistas y proveedores que accedan a los sistemas o información de la organización.

Este documento es revisado anualmente por el Comité de Seguridad de la Información y actualizado cada vez que ocurran cambios organizacionales, tecnológicos o normativos relevantes.

Control	Título	Estado	Madurez	Riesgo
A.5.2	Roles y responsabilidades de seguridad	Implementado	3	Medio
A.5.25	Evaluación de eventos de seguridad	Parcialmente implementado	2	Alto
A.5.35	Revisión independiente de seguridad	Parcialmente implementado	3	Medio
A.5.36	Cumplimiento de políticas y normas	Parcialmente implementado	2	Alto
A.6.3	Concienciación, educación y capacitación	Implementado	4	Bajo

A.5.2

Roles y responsabilidades en seguridad de la información

2. Política de roles y responsabilidades de seguridad (A.5.2)

La organización define, documenta y comunica formalmente las responsabilidades de seguridad de la información para todos los roles que impliquen acceso, gestión o supervisión de activos de información. La asignación de responsabilidades sigue el principio de segregación de funciones.

2.1 Responsabilidades por rol

Rol	Responsabilidades principales de seguridad	Área
CISO	Definir estrategia de seguridad, aprobar políticas, reportar al directorio.	Seguridad TI
Administrador de sistemas	Gestionar accesos, aplicar parches, mantener configuraciones seguras.	TI / Infraestructura
Propietario de activo	Clasificar la información, autorizar accesos, revisar permisos.	Todas las áreas
Usuario final	Cumplir políticas, reportar incidentes, proteger credenciales.	Todas las áreas
Proveedor externo	Firmar acuerdo de confidencialidad, cumplir controles contractuales.	Contratos

2.2 Procedimiento de asignación y revisión de roles

Al incorporarse un nuevo integrante, RRHH notifica a Seguridad TI para asignar los roles correspondientes según el perfil del cargo. Los roles se revisan semestralmente y ante cualquier cambio de función, promoción o desvinculación. Los cambios quedan registrados en el sistema de gestión de identidades (IAM).

2.3 Registros de comunicación de responsabilidades

Fecha	Actividad	Participantes	Responsable	Medio
12/01/2025	Inducción SGSI para nuevos ingresos Q4-2024	14 personas	CISO	LMS corporativo
20/03/2025	Actualización matriz de roles tras reestructura TI	Equipo TI (8)	Jefe TI	Acta firmada
15/06/2025	Revisión semestral de asignaciones de acceso	Propietarios de activos	CISO	Informe IAM
10/09/2025	Comunicación política actualizada v2.1	Toda la organización	CISO	Correo + firma

A.5.25

Evaluación y decisión sobre eventos de seguridad de la información

3. Procedimiento de evaluación de eventos de seguridad (A.5.25)

Todo evento de seguridad detectado debe ser evaluado para determinar si constituye un incidente de seguridad de la información. Esta evaluación es realizada por el equipo de Operaciones de Seguridad dentro de las 4 horas hábiles siguientes a la detección del evento.

3.1 Criterios de clasificación de eventos

Categoría	Criterio de decisión	Acción requerida	Responsable
Evento sin impacto	No afecta CIA. Origen identificado y benigno.	Registrar y cerrar.	Analista SOC
Evento de bajo impacto	Afecta parcialmente un activo no crítico.	Registrar. Revisar en 24h.	Analista SOC
Incidente moderado	Afecta activo crítico o datos sensibles de forma acotada.	Escalar a Coordinador SI.	Coordinador SI
Incidente grave	Afecta múltiples sistemas, datos personales o continuidad.	Activar Plan de Respuesta.	CISO

3.2 Proceso de evaluación (flujo)

- **Detección:** el evento es reportado por monitoreo SIEM, usuario o proveedor.
- **Registro inicial:** se registra en el sistema de tickets con fecha, hora, origen y descripción.
- **Análisis preliminar (máx. 4h hábiles):** el analista SOC aplica los criterios de la tabla 3.1.
- **Decisión:** se clasifica como evento sin impacto, bajo impacto o incidente, y se documenta la justificación.
- **Escalamiento:** si es incidente, se activa el procedimiento de respuesta (PRO-INC-002).
- **Cierre y aprendizaje:** todo evento se cierra con lección aprendida documentada.

3.3 Registro de evaluaciones realizadas (muestra)

ID Evento	Fecha	Descripción	Clasificación	Decisión / Acción	Cierre
EVT-2025-041	03/02/2025	Intento de login fallido x5 en cuenta admin	Bajo impacto	Monitoreo extendido 48h. Sin escalamiento.	05/02/2025
EVT-2025-087	14/03/2025	Correo phishing recibido y reportado por usuario	Evento sin impacto	Bloqueado en gateway. Sensibilización al área.	14/03/2025
EVT-2025-112	28/04/2025	Acceso no autorizado a carpeta de RRHH	Incidente moderado	Escalado. Acceso revocado. Investigación interna.	05/05/2025
EVT-2025-198	11/07/2025	Servidor de backup sin respuesta > 6h	Incidente moderado	Escalado a TI. Restauración desde snapshot.	12/07/2025

A.5.35

Revisión independiente de la seguridad de la información

4. Política y procedimiento de revisión independiente (A.5.35)

La organización realiza revisiones independientes del Sistema de Gestión de Seguridad de la Información (SGSI) al menos una vez al año, mediante auditorías internas y externas, para evaluar objetivamente la efectividad de los controles implementados. El revisor debe ser independiente del área auditada y contar con competencias acreditadas en seguridad de la información.

4.1 Tipos de revisión y frecuencia

Tipo de revisión	Frecuencia	Ejecutado por	Criterio de independencia
Auditoría interna SGSI	Anual (Q1)	Auditor interno certificado ISO 27001	No pertenece al área de TI ni Seguridad
Revisión por la dirección	Semestral	Comité SGSI + Directorio	Alta dirección, independiente de operaciones
Auditoría externa (certificación)	Trienal + seguimiento anual	Organismo de certificación acreditado	Entidad externa a la organización
Revisión técnica de controles	Trimestral	Consultor externo de SI	Externo contratado para este fin

4.2 Procedimiento de revisión independiente

Planificación: el CISO coordina el programa anual de auditorías en enero de cada año, definiendo alcance, criterios, auditor y fechas. El programa es aprobado por la dirección.

Ejecución: el auditor realiza entrevistas, revisión documental y pruebas técnicas según el plan acordado. Durante la auditoría no puede ser dirigido ni supervisado por el área auditada.

Informe de hallazgos: al concluir, el auditor emite un informe con hallazgos, no conformidades y recomendaciones. El informe se entrega al CISO y a la dirección.

Plan de acción: el área auditada elabora un plan de acción correctiva en un plazo máximo de 15 días hábiles desde la recepción del informe.

4.3 Registro de revisiones independientes realizadas

Periodo	Tipo	Auditor / Entidad	Acreditación	Hallazgos NC	Estado plan acción
Ene-Feb 2024	Auditoría interna SGSI	María González (Lead Auditor ISO 27001)	CQI-IRCA #48921	2 menores	Cerrado 15/04/2024
Jun 2024	Revisión dirección	Comité SGSI	N/A (alta dirección)	0	N/A
Oct 2024	Auditoría externa (seguimiento)	Bureau Veritas Chile	ENAC acreditado	1 mayor, 1 menor	En curso (cierre dic-2025)
Ene 2025	Revisión técnica controles A.8	Consultor Externo — CyberPro Ltda.	CISSP #334812	3 menores	Cerrado 28/02/2025

A.5.36

Cumplimiento con políticas, reglas y normas de seguridad de la información

5. Política de verificación de cumplimiento (A.5.36)

La organización verifica periódicamente que los procesos, sistemas y personas cumplan con las políticas internas de seguridad y los requisitos normativos aplicables (ISO/IEC 27001:2022, Ley 19.628 de protección de datos personales, regulaciones sectoriales). Esta verificación es responsabilidad del área de Legal y Cumplimiento en coordinación con el CISO.

5.1 Marco de políticas y normas aplicables

Política / Norma	Ámbito de aplicación	Responsable de verificación	Frecuencia
POL-SGSI-001 (este documento)	Toda la organización	CISO	Anual
POL-ACC-002 — Control de accesos	TI, RRHH	Jefe TI	Semestral
POL-CRIPTO-003 — Uso de criptografía	TI, Desarrollo	Jefe TI	Anual
POL-INC-004 — Gestión de incidentes	Operaciones, TI	Coordinador SI	Semestral
Ley 19.628 — Protección de datos	RRHH, Marketing, Legal	Legal y Cumplimiento	Anual
ISO/IEC 27001:2022 Anexo A	Toda la organización	CISO + Auditor	Anual (auditoría)

5.2 Procedimiento de verificación de cumplimiento

- Identificación del universo:** Legal y Cumplimiento mantiene actualizado el registro de políticas y normas aplicables, revisado al inicio de cada año.
- Evaluación de cumplimiento:** se aplica un checklist por política, con entrevistas y revisión de evidencia documental al área responsable.
- Registro de resultados:** los hallazgos quedan registrados en el sistema de cumplimiento (GRC Tool) con nivel de cumplimiento, brechas y plazo de subsanación.
- Seguimiento:** las brechas identificadas son seguidas mensualmente hasta su cierre.
- Reporte a la dirección:** Legal y Cumplimiento reporta trimestralmente al Comité SGSI el estado general de cumplimiento.

5.3 Registros de verificación de cumplimiento

Política / Norma	Fecha revisión	Área evaluada	% Cumplimiento	Brechas	Estado
POL-SGSI-001	20/01/2025	Toda la organización	87%	2 brechas menores	En subsanación
POL-ACC-002	15/03/2025	TI / Infraestructura	94%	1 brecha menor	Cerrada 30/04/2025
Ley 19.628	10/04/2025	RRHH + Marketing	78%	3 brechas (1 mayor)	Plan acción activo

Política / Norma	Fecha revisión	Área evaluada	% Cumplimiento	Brechas	Estado
POL-INC-004	05/06/2025	Operaciones	91%	1 brecha menor	Cerrada 20/06/2025

A.6.3

Concienciación, educación y capacitación en seguridad de la información

6. Programa de concienciación y capacitación en seguridad (A.6.3)

La organización mantiene un programa continuo de concienciación, educación y capacitación en seguridad de la información, orientado a que todo el personal comprenda su responsabilidad en la protección de los activos de información y sea capaz de identificar amenazas, reportar eventos y actuar conforme a las políticas vigentes.

6.1 Política de formación en seguridad

Todo el personal de Empresa Demo S.A., incluyendo personal temporal y contratistas con acceso a sistemas o información, debe completar al menos **8 horas anuales** de formación en seguridad de la información. La formación es obligatoria, su registro se mantiene en el LMS corporativo y es condición para mantener los accesos asignados.

6.2 Plan de formación 2025

Módulo	Audiencia	Duración	Modalidad	Fecha	Responsable
Inducción SGSI — Nuevos ingresos	Nuevos colaboradores	3h	Presencial + LMS	Mensual	CISO
Phishing y amenazas de ingeniería social	Toda la organización	1.5h	LMS + simulacro	Q1 2025	Coordinador SI
Clasificación y manejo de información	Todas las áreas	1h	LMS	Q2 2025	CISO
Gestión de contraseñas y MFA	Usuarios TI	1h	LMS + taller	Q2 2025	Jefe TI
Respuesta ante incidentes — qué hacer	Toda la organización	1h	LMS	Q3 2025	Coordinador SI
Trabajo remoto seguro	Personal híbrido/remoto	1h	LMS	Q3 2025	CISO
Simulacro de phishing (evaluación)	Toda la organización	—	Simulado	Q4 2025	Proveedor externo
Revisión anual política SGSI	Toda la organización	0.5h	LMS	Q4 2025	CISO

6.3 Registros de formación realizadas

Módulo	Fecha	N° Participantes	% Cobertura	Nota promedio	Registro
Inducción SGSI Q4-2024	10/01/2025	18	100% nuevos ingresos	88/100	LMS-REC-2025-001
Phishing y amenazas sociales	28/02/2025	143	96% organización	No aplica	LMS-REC-2025-012
Clasificación de información	15/04/2025	148	99% organización	91/100	LMS-REC-2025-028
Gestión de contraseñas y MFA	20/05/2025	42	100% usuarios TI	94/100	LMS-REC-2025-035
Respuesta ante incidentes	18/07/2025	145	97% organización	89/100	LMS-REC-2025-051

6.4 Evaluación de efectividad del programa

La efectividad del programa se mide mediante: (1) tasa de éxito en simulacros de phishing (objetivo: tasa de clic < 5%), (2) nota promedio en evaluaciones de conocimiento (objetivo: > 80/100), y (3) número de eventos de seguridad atribuibles a error humano (objetivo: reducción del 20% anual). Los resultados se reportan trimestralmente al Comité SGSI.

Indicador	Meta 2025	Resultado Q2 2025	Tendencia
Tasa de clic en simulacro phishing	< 5%	7.2% (↓ desde 12% en 2024)	Mejorando
Nota promedio evaluaciones	> 80/100	90.5/100	Cumplido
Eventos por error humano	Reducción 20%	Reducción 14% vs 2024	En seguimiento
Cobertura formación anual	> 95% personal	97% acumulado Q2	Cumplido

7. Control de versiones y registro de aprobaciones

Versión	Fecha	Descripción del cambio	Autor	Aprobado por
1.0	15/01/2023	Versión inicial del documento.	CISO	Directorio
1.1	20/06/2023	Incorporación de control A.5.25 (nuevo en ISO 27001:2022).	Coordinador SI	CISO
2.0	15/01/2024	Revisión completa. Incorporación A.5.35 y A.5.36.	CISO	Comité SGSI
2.1	15/01/2025	Actualización registros, plan formación 2025, indicadores KPI.	CISO	Comité SGSI

Documento de prueba generado con datos sintéticos para validar un agente de análisis ISO 27001. No constituye una política oficial ni una reproducción del texto normativo de la norma ISO/IEC 27001:2022. Empresa Demo S.A. es una organización ficticia creada exclusivamente para este ejercicio.